



Universidade do Minho  
Escola de Engenharia

Universidade do Minho  
Escola de Engenharia

# Relatório do trabalho prático de Laboratórios de Cibersegurança (Módulo 1)

Rui Carvalho, n.º PG59797  
Tiago Baganha, n.º PG60307  
João Silva, n.º PG60986

2025 - 2026  
Prof. Doutor. João Marco Cardoso Silva

# Conteúdo

|                                                                                                 |          |
|-------------------------------------------------------------------------------------------------|----------|
| <b>Índice de imagens</b>                                                                        | <b>2</b> |
| <b>1 Introdução</b>                                                                             | <b>1</b> |
| <b>2 Arquitetura do Sistema</b>                                                                 | <b>1</b> |
| 2.1 Componentes Principais . . . . .                                                            | 1        |
| 2.2 Fluxos Principais . . . . .                                                                 | 2        |
| <b>3 Requisitos de Segurança</b>                                                                | <b>2</b> |
| <b>4 Modelo de Ameaça STRIDE</b>                                                                | <b>2</b> |
| 4.1 Mapeamento do modelo STRIDE para Frameworks de segurança e monitorização contínua . . . . . | 3        |
| <b>5 Arquitetura de Monitorização</b>                                                           | <b>5</b> |
| 5.1 Especificação de métricas e eventos a recolher . . . . .                                    | 5        |
| 5.2 Contextualização da Monitorização . . . . .                                                 | 5        |
| 5.3 Objetivos da Monitorização . . . . .                                                        | 6        |
| 5.4 Arquitetura de Monitorização . . . . .                                                      | 6        |
| 5.4.1 Camada de Recolha . . . . .                                                               | 6        |
| 5.4.2 Camada de Processamento . . . . .                                                         | 7        |
| 5.4.3 Camada de Armazenamento . . . . .                                                         | 7        |
| 5.4.4 Camada de Visualização . . . . .                                                          | 7        |
| <b>6 Análise de ameaças com OSINT e CTI</b>                                                     | <b>7</b> |
| 6.1 Ameaças seleccionadas . . . . .                                                             | 8        |
| 6.1.1 Ameaça 1 - Adulteração dos certificados dos utilizadores . . . . .                        | 8        |
| 6.1.2 Ameaça 2 - Substituição do certificado da CA . . . . .                                    | 8        |
| <b>7 Integração do OSINT/CTI na monitorização</b>                                               | <b>9</b> |
| 7.1 Tradução de IoCs e TTPs em regras de deteção . . . . .                                      | 9        |
| 7.2 Demonstração de Deteção de Ataques . . . . .                                                | 9        |
| 7.2.1 Substituição do Certificado da CA . . . . .                                               | 9        |
| 7.2.2 Modificação de Certificado de Utilizador . . . . .                                        | 11       |
| 7.2.3 Ligação Externa à Base de Dados e Tentativa de Exfiltração . . . . .                      | 12       |
| 7.3 Monitorização através do Dashboard . . . . .                                                | 14       |
| 7.4 Integração do ciclo de inteligência . . . . .                                               | 14       |
| 7.5 Conclusão . . . . .                                                                         | 15       |

# Índice de imagens

## Lista de Figuras

|    |                                                                 |    |
|----|-----------------------------------------------------------------|----|
| 1  | Diagrama de Fluxo de Dados . . . . .                            | 1  |
| 2  | Arquitetura Monitorização . . . . .                             | 9  |
| 3  | Log da monitorização . . . . .                                  | 10 |
| 4  | Estado dos alertas . . . . .                                    | 10 |
| 5  | Email do alerta . . . . .                                       | 11 |
| 6  | Log monitorização . . . . .                                     | 11 |
| 7  | Alerta da modificação do certificado . . . . .                  | 12 |
| 8  | Email do alerta . . . . .                                       | 12 |
| 9  | Logs da ligação externa e exfiltração de certificados . . . . . | 13 |
| 10 | Alerta no grafana . . . . .                                     | 13 |
| 11 | Emails dos alertas . . . . .                                    | 13 |
| 12 | Alerta via Email . . . . .                                      | 14 |

# 1 Introdução

O presente relatório descreve a estratégia de monitorização contínua aplicada a um sistema de leilões entre pares com elevados requisitos de segurança. O trabalho centra-se na análise de ameaças e na definição de mecanismos capazes de detetar e responder a incidentes de segurança. Para esse efeito, são utilizados modelos de análise de ameaças e estruturas de segurança reconhecidas, bem como informação de fontes OSINT e CTI.

## 2 Arquitetura do Sistema

O sistema desenvolvido corresponde a uma plataforma de leilões peer-to-peer, concebida com um enfoque rigoroso na segurança, auditabilidade e privacidade dos participantes. A arquitetura adotada segue uma abordagem modular, composta por serviços independentes que representam diferentes entidades de confiança. A separação de responsabilidades constitui um princípio fundamental do sistema, sendo que a CA Server gere a identidade, a TSA Server assegura a temporalidade, a Blockchain garante a imutabilidade dos registos e o Peer Server coordena a comunicação distribuída. Esta divisão reduz a superfície de ataque e limita o impacto de um eventual comprometimento. O diagrama de fluxo de dados (DFD) apresentado na Figura 1 ilustra de forma clara e precisa os principais componentes e os fluxos de informação entre eles.

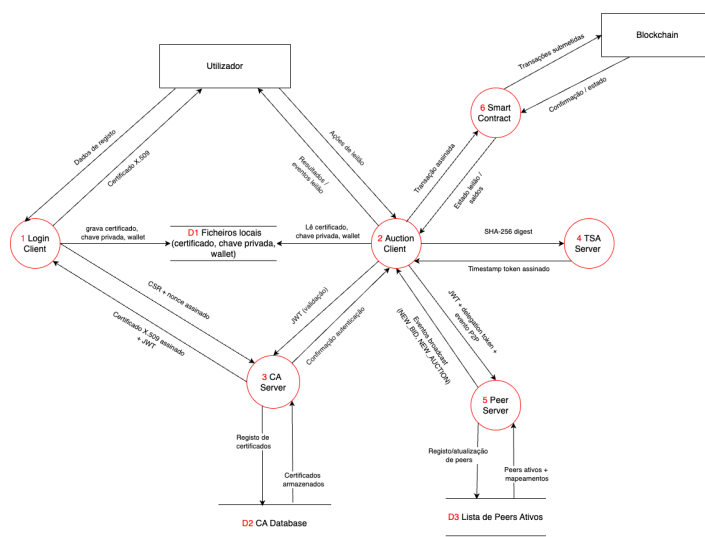


Figura 1: Diagrama de Fluxo de Dados

### 2.1 Componentes Principais

#### Processos

O sistema é composto por vários componentes, cada um com um papel específico no funcionamento do leilão. O **Login Client** constitui o ponto de entrada do utilizador, sendo responsável pela autenticação inicial e pela gestão local das credenciais, incluindo o armazenamento do certificado X.509, da chave privada e da wallet nos ficheiros locais (D1). O **Auction Client** atua como o núcleo operacional da aplicação, gerindo as

interações do utilizador com o sistema, processando transações e comunicando com a TSA Server para a marcação de tempo, com o Peer Server para a descoberta de pares, com o Smart Contract para a execução da lógica de negócio e com a CA Server para a autenticação. A **CA Server** (Certificate Authority) é a entidade responsável pela emissão de certificados digitais, processando pedidos CSR assinados, emitindo certificados X.509 e fornecendo tokens JWT para autenticação, além de manter o registo de certificados na base de dados da CA (D2). A **TSA Server** (Timestamp Authority) é responsável por garantir a prova temporal das transações, mediante a receção de um digest SHA-256 e a subsequente devolução de um token de timestamp assinado. O **Peer Server** gere a rede peer-to-peer, o que inclui a manutenção da lista de peers ativos e a prestação de informações ao Auction Client sobre os nós disponíveis. Por fim, o **Smart Contract** executa a lógica do leilão na blockchain, onde são processadas transações assinadas e registado o estado das operações de forma imutável.

## 2.2 Fluxos Principais

- **Registo/Autenticação:** O utilizador envia dados ao Login Client → CSR assinado enviado à CA Server → CA emite certificado X.509 → guardado localmente em D1.
- **Sessão de Leilão:** Login Client autentica no Auction Client via JWT → utilizador interage com o leilão → Auction Client coordena com TSA (timestamp), Peer Server (rede P2P) e Smart Contract (lógica de negócio).
- **Transação em Blockchain:** Auction Client envia transação assinada ao Smart Contract → Smart Contract regista na Blockchain → confirma estado de volta ao Auction Client.
- **Timestamping:** Auction Client gera SHA-256 digest → envia à TSA → recebe token assinado com timestamp, garantindo não-repúdio temporal.

## 3 Requisitos de Segurança

O sistema de leilões deve garantir propriedades de segurança fundamentais, nomeadamente anonimato, autenticidade, integridade, não repúdio e temporalidade verificável. O anonimato dos participantes é garantido por meio de pseudónimos efémeros, associados a pares de chaves gerados localmente para cada leilão. A garantia da autenticidade das entidades é assegurada por certificados digitais X.509, emitidos pela Autoridade Certificadora (CA). A integridade das licitações é assegurada por assinaturas digitais e pelo registo das transações na blockchain, enquanto o não repúdio resulta da utilização combinada de certificados digitais, assinaturas criptográficas e timestamps emitidos pela Timestamp Authority (TSA). Após a conclusão do leilão, o sistema permite a revelação seletiva da identidade, possibilitando apenas ao vendedor e ao vencedor identificarem-se mutuamente.

## 4 Modelo de Ameaça STRIDE

A análise de ameaças foi realizada utilizando o modelo STRIDE, que permite classificar diferentes tipos de ataques possíveis no sistema. Esta abordagem facilita a identifica-

ção de vulnerabilidades associadas aos vários componentes da arquitetura e permite orientar a definição de mecanismos de monitorização e controlo de segurança. A tabela seguinte apresenta um resumo das principais ameaças identificadas, os componentes potencialmente afetados e uma breve descrição do impacto no sistema.

| Ameaça             | CA Server | TSA Server | Peer Server | Blockchain/Smart Cont. | Login Client | Auction Client | Canal P2P | Fich. Locais | CA DB |
|--------------------|-----------|------------|-------------|------------------------|--------------|----------------|-----------|--------------|-------|
| Spoofing           | x         | x          | x           |                        | x            | x              |           | x            |       |
| Data Tampering     | x         | x          | x           | x                      |              | x              | x         | x            | x     |
| Repudiation        | x         | x          | x           |                        |              | x              |           | x            |       |
| Info. Disclosure   | x         | x          | x           | x                      | x            | x              | x         | x            | x     |
| Denial of Service  | x         | x          | x           | x                      |              | x              | x         | x            | x     |
| Elev. of Privilege | x         |            | x           |                        |              |                |           | x            | x     |

Tabela 1: Modelo de Ameaça STRIDE – Componentes Afetados

| Categoria STRIDE       | Ativos afetados                                                                        | Descrição                                                                        |
|------------------------|----------------------------------------------------------------------------------------|----------------------------------------------------------------------------------|
| Spoofing               | TSA Server, Peer Server, Login Client, Auction Client, Ficheiros Locais                | Personificação de utilizadores ou serviços através de credenciais comprometidas. |
| Data Tampering         | CA Server, TSA Server, Peer Server, Blockchain, Auction Client, Canal P2P, CA Database | Alteração de mensagens, ficheiros locais ou registos de certificados.            |
| Repudiation            | CA Server, TSA Server, Auction Client                                                  | Negação de ações realizadas devido à ausência de registos verificáveis.          |
| Information Disclosure | Todos os componentes                                                                   | Exposição de chaves privadas, certificados ou dados do leilão.                   |
| Denial of Service      | CA Server, TSA Server, Peer Server, Blockchain, Canal P2P                              | Indisponibilidade de serviços críticos do sistema.                               |
| Elevation of Privilege | CA Server, Peer Server, CA Database, Ficheiros Locais                                  | Obtenção de privilégios elevados ou emissão fraudulenta de certificados.         |

Tabela 2: Descrição das Ameaças STRIDE

#### 4.1 Mapeamento do modelo STRIDE para Frameworks de segurança e monitorização contínua

Para garantir alinhamento com boas práticas reconhecidas internacionalmente e enquadrar a estratégia de monitorização contínua, procedeu-se ao mapeamento das ameaças identificadas para frameworks de referência na área da cibersegurança.

Este mapeamento permite traduzir categorias abstratas de ameaça em controlos concretos e funções de monitorização operacional. Em particular, foram considerados:

- O framework **MITRE ATT&CK**, para identificação de táticas e técnicas de ataque (TTPs) relevantes para o contexto da Autoridade Certificadora;

- O **NIST SP 800-137**, como modelo estruturante de Continuous Monitoring, permitindo associar cada ameaça a funções específicas de controlo, auditoria e deteção;
- Controlos técnicos implementáveis no contexto do CA Server, garantindo aplicabilidade prática.

A tabela seguinte apresenta a correspondência entre as categorias STRIDE aplicáveis ao CA Server, as técnicas de ataque mais relevantes segundo o MITRE ATT&CK, os controlos de monitorização segundo o NIST SP 800-137 e as medidas técnicas concretas adotadas.

Tabela 3: Mapeamento STRIDE – MITRE ATT&CK – NIST SP 800-137

| <b>Ameaça STRIDE</b>   | <b>MITRE ATT&amp;CK</b>                                                                                                                                     | <b>NIST SP 800-137</b>                                               | <b>Controlos técnicos</b>                                                                                           |
|------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------|
| Spoofing               | T1078 - Valid Accounts<br>T1036 - Masquerading                                                                                                              | AC-2 - Account Management<br>IA-2 - Identification & Authentication  | Logging de pedidos de certificado X.509<br>Autenticação mútua TLS                                                   |
| Data Tampering         | T1565.001 - Stored data manipulation<br>T1553.004 - Install Root Certificate<br>T1190 - Exploit Public-Facing Application<br>T1005 - Data from Local System | SI-7 - Software & Information Integrity<br>AU-12 - Audit Generation  | Monitorização da integridade dos ficheiros com hash                                                                 |
| Repudiation            | T1070 - Indicator removal                                                                                                                                   | AU-6 - Audit Review, Analysis & Reporting<br>AU-8 - Time Stamps      | Armazenamento seguro de evidências<br>Logs imutáveis de emissão/revogação de certificados                           |
| Information Disclosure | T1567 - Exfiltration Over Web Service<br>T1212 - Exploitation for Credential Access                                                                         | IA-5 - Authenticator Management<br>AC-3 - Access Enforcement         | HSM ou armazenamento seguro da chave privada<br>Encriptação da CA DB                                                |
| Denial of Service      | T1498 - Network DoS<br>T1499 - Endpoint DoS                                                                                                                 | SC-5 - Denial of Service Protection<br>IR-5 - Incident Monitoring    | Rate limiting em pedidos CSR<br>Monitorização de latência e carga<br>Alertas por excesso de pedidos                 |
| Elevation of Privilege | T1068 - Exploitation for Privilege Escalation                                                                                                               | AC-5 - Separation of Duties<br>CM-5 - Access Restrictions for Change | Separação de funções CA, TSA e Peer Server<br>Monitorização de contas admin<br>Alertas para alteração de permissões |

## 5 Arquitetura de Monitorização

### 5.1 Especificação de métricas e eventos a recolher

Após o mapeamento das ameaças para frameworks de segurança reconhecidos, tornou-se necessário traduzir esses controlos em mecanismos operacionais de monitorização contínua. A eficácia de uma estratégia de segurança não depende apenas da existência de controlos, mas da capacidade de detetar, em tempo útil, desvios ao comportamento esperado. Neste contexto, foram definidos eventos monitorizáveis, métricas quantitativas, limiares de alerta (thresholds) e ações automáticas de resposta para o CA Server, enquanto componente crítico da cadeia de confiança do sistema. Cada evento identificado está associado a uma métrica mensurável (por exemplo, número de falhas por endereço IP ou número de acessos não autorizados), a um limiar de disparo e a uma ação de resposta previamente definida. Esta abordagem permite transformar requisitos abstratos de segurança em regras concretas de deteção e resposta, alinhadas com os princípios de continuous monitoring.

A tabela seguinte apresenta a correspondência entre ameaças STRIDE, eventos monitorizados, métricas associadas, critérios de ativação e ações automáticas de contenção ou alerta.

| Ameaça STRIDE          | Evento                                                            | Métrica                                   | Threshold    | Ação                                               |
|------------------------|-------------------------------------------------------------------|-------------------------------------------|--------------|----------------------------------------------------|
| Spoofing               | Falhas de validação do CSR                                        | Nº falhas por IP                          | >5 em 2 min  | Alerta + bloqueio temporário do IP                 |
| Data Tampering         | Alteração na CA BD                                                | Hash mismatch                             | 1 ocorrência | Alerta crítico + suspensão do serviço              |
| Repudiation            | Tentativa de eliminar registo de emissão/revogação de certificado | Evento de delete                          | 1 ocorrência | Alerta crítico + notificação do admin              |
| Information Disclosure | Acesso à Base de dados da CA por utilizador não autorizado        | Acessos não-admin à BD                    | 1 ocorrência | Alerta crítico + revogação de acesso               |
| Denial of Service      | Pico de pedidos CSR                                               | Pedidos/min                               | > 100/min    | Rate limiting                                      |
| Elevation of Privilege | Emissão de certificado com atributos anómalos (ca=true)           | Certificados emitidos com atributos de CA | 1 ocorrência | Alerta crítico + revogação imediata do certificado |

Tabela 4: Eventos, Métricas e Ações de Monitorização

### 5.2 Contextualização da Monitorização

O CA Server constitui o elemento central de confiança do sistema de leilões, sendo responsável pela emissão e armazenamento de certificados digitais utilizados na autenticação das entidades. A base de dados PostgreSQL armazena tanto o certificado da autoridade certificadora como os certificados individuais dos utilizadores. Qualquer



modificação não autorizada destes registos compromete diretamente a segurança do sistema, possibilitando acessos indevidos ou a falsificação de identidade.

A análise baseada no modelo STRIDE permitiu identificar vulnerabilidades relevantes, nomeadamente a ausência de mecanismos robustos de proteção ao nível do armazenamento dos certificados e a possibilidade de manipulação direta dos registos da base de dados. Neste contexto, a integridade dos certificados foi definida como um dos principais casos de uso para a implementação de mecanismos de monitorização contínua.

### 5.3 Objetivos da Monitorização

A estratégia de monitorização aplicada ao CA Server tem como finalidade assegurar visibilidade operacional sobre o estado de integridade dos certificados e permitir a deteção atempada de incidentes de segurança. Em particular, os objetivos definidos incluem:

- Detetar alterações não autorizadas aos certificados armazenados
- Identificar o momento em que ocorre a adulteração
- Garantir baixa latência na deteção de violações de integridade
- Preservar evidências relevantes para análise posterior

A monitorização incide sobre diferentes categorias de eventos, nomeadamente eventos de base de dados, eventos aplicacionais e eventos associados a acessos ao sistema. Ao nível da base de dados, são monitorizadas divergências de hash criptográfico nos certificados armazenados, sendo classificadas como críticas quando afetam o certificado da autoridade certificadora e como advertências quando afetam certificados de utilizadores.

Ao nível aplicacional, são registadas operações relevantes associadas à gestão de certificados e à execução de verificações de integridade. Adicionalmente, são monitorizadas conexões externas ao servidor PostgreSQL, com o objetivo de identificar acessos diretos potencialmente não autorizados.

A partir da análise destes eventos, são derivadas métricas operacionais relacionadas com a integridade dos certificados, a frequência de alterações detetadas e a ocorrência de acessos externos ao sistema.

### 5.4 Arquitetura de Monitorização

A arquitetura de monitorização adotada segue uma abordagem modular baseada em camadas funcionais, que se distribuem pelos níveis de recolha, processamento, armazenamento e visualização de eventos.

#### 5.4.1 Camada de Recolha

Na camada de recolha, são utilizados mecanismos específicos que garantem a visibilidade do estado de integridade dos certificados.

- **Verificação periódica de integridade por hashing**, executada por um processo autónomo. Este recalcula o hash SHA-256 dos certificados armazenados e

procede à sua comparação com o valor de referência previamente definido.

- **Logging aplicativo**, responsável pelo registo estruturado de eventos relevantes relacionados com alterações aos certificados e acessos externos ao sistema.

#### 5.4.2 Camada de Processamento

Os eventos recolhidos são encaminhados para uma plataforma centralizada de análise, onde são normalizados e indexados. Este processamento possibilita a aplicação de regras de deteção baseadas em padrões previamente definidos, permitindo a identificação de incidentes de segurança associados à integridade dos certificados.

#### 5.4.3 Camada de Armazenamento

Os eventos de segurança são armazenados num sistema centralizado, independente do servidor monitorizado. Desta forma, é garantida a preservação de provas em caso de violação da segurança. Esta abordagem possibilita o apoio a atividades de auditoria e investigação forense.

#### 5.4.4 Camada de Visualização

A visualização dos eventos é efetuada através de dashboards desenvolvidos na plataforma Grafana, os quais apresentam indicadores agregados sobre o estado de integridade do sistema, bem como tabelas detalhadas com eventos de violação e acessos externos à base de dados. Estas visualizações permitem identificar de forma expedita comportamentos anómalos e apoiar a análise de incidentes.

## 6 Análise de ameaças com OSINT e CTI

A pesquisa focou-se no vetor de alteração maliciosa dos certificados presentes na base de dados, pois este foi o risco mais crítico identificado para o CA Server. Para identificar as ameaças relevantes à integridade dos certificados, foram consultadas as seguintes fontes:

- **MITRE ATT&CK** – Identificação de TTPs relevantes para manipulação de dados armazenados em sistemas PKI
- **CISA Advisories** – Alertas sobre ataques a infraestruturas de certificados digitais
- **CERT/CC** – relatórios de incidentes que envolveram comprometimento de CAs e manipulação de certificados

A análise destas fontes permitiu identificar técnicas de ataque relacionadas com a manipulação de dados armazenados e comprometimento de infraestruturas de certificação. No contexto do sistema analisado, estas ameaças podem manifestar-se através da modificação não autorizada de certificados na base de dados ou da substituição do certificado da autoridade certificadora. Com base nestes cenários, foram definidos alguns indicadores de compromisso.

## 6.1 Ameaças selecionadas

### 6.1.1 Ameaça 1 - Adulteração dos certificados dos utilizadores

**TTP T1565.001 - Stored Data Manipulation:** Um atacante que tenha acesso direto à base de dados pode alterar o certificado de um utilizador. A partir deste momento, o atacante passa a autenticar-se no sistema como esse utilizador e pode participar em leilões sob a identidade dessa pessoa.

**Caso real:** Em 2011, um parceiro da Comodo CA foi comprometido e um atacante obteve acesso ao sistema de emissão de certificados, conseguindo manipular registos para emitir 9 certificados falsificados para domínios como Google, Yahoo e Skype.

#### IoCs

| IoC                                                            | Tipo             | Descrição                                               |
|----------------------------------------------------------------|------------------|---------------------------------------------------------|
| Hash SHA-256 do certificado do utilizador diverge da base-line | Hash mismatch    | Conteúdo do certificado foi alterado directamente na BD |
| Conexão direta ao PostgreSQL a partir de IP não esperado       | Conexão suspeita | Acesso não mediado pela aplicação                       |

#### Regra de deteção

```
Se current["USER:<username>:<serial>"] != baseline["USER:<username>:<serial>"]
-> ALERTA WARNING: HASH_MISMATCH
```

### 6.1.2 Ameaça 2 - Substituição do certificado da CA

**TTP T1553.004 - Subvert Trust Controls: Install Root Certificate:** Um atacante que comprometa o CA Server pode substituir o certificado raiz da entidade, podendo controlar toda a cadeia de confiança. Após possuir o certificado raiz, qualquer certificado fraudulento emitido é sempre considerado legítimo.

**Caso real:** Em 2011, a CA holandesa DigiNotar foi comprometida e atacantes substituíram certificados raiz, emitindo mais de 500 certificados fraudulentos para domínios críticos incluindo o Google e serviços governamentais iranianos.

#### IoCs

| IoC                                                      | Tipo             | Descrição                                               |
|----------------------------------------------------------|------------------|---------------------------------------------------------|
| Hash SHA-256 do certificado da CA diverge da baseline    | Hash mismatch    | Conteúdo do certificado foi alterado directamente na BD |
| Conexão direta ao PostgreSQL a partir de IP não esperado | Conexão suspeita | Acesso não mediado pela aplicação                       |

#### Regra de deteção

```
Se current["CA:<serial>"] != baseline["CA:<serial>"]
-> ALERTA CRITICAL: HASH_MISMATCH
```

## 7 Integração do OSINT/CTI na monitorização

### 7.1 Tradução de IoCs e TTPs em regras de deteção

A análise feita na secção anterior permitiu identificar diferentes técnicas utilizadas por atacantes no contexto de infraestruturas de certificados digitais, tal como a manipulação de dados armazenados e o comprometimento de repositórios de certificados. Estas técnicas foram traduzidas em indicadores de compromisso que podem ser detetados pelo sistema de monitorização implementado.

Cada um destes indicadores está associado a regras de deteção implementadas através da verificação periódica de integridade e análise de logs da aplicação. Em relação ao primeiro IoC, para cada certificado presente, é calculado o hash SHA-256 do conteúdo atual e comparado com o valor original registado. No que diz respeito ao segundo IoC, é feita uma monitorização dos logs de modo a detetar operações realizadas por IPs suspeitos.

Quando uma destas condições é detetada, o sistema gera um evento de segurança e um respetivo alerta, com diferentes níveis de severidade dependendo do alvo atacado: por exemplo, CRITICAL para o certificado raiz da CA e WARNING para os certificados dos utilizadores.

### 7.2 Demonstração de Deteção de Ataques

A fim de validar a estratégia de monitorização contínua proposta, foram simulados vários cenários de ataque no ambiente do CA Server. Cada cenário demonstra a capacidade do sistema de monitorização em detetar eventos de segurança, através da análise de registos, avaliação de métricas e geração automática de alertas.

A arquitetura da pipeline de monitorização é a seguinte:

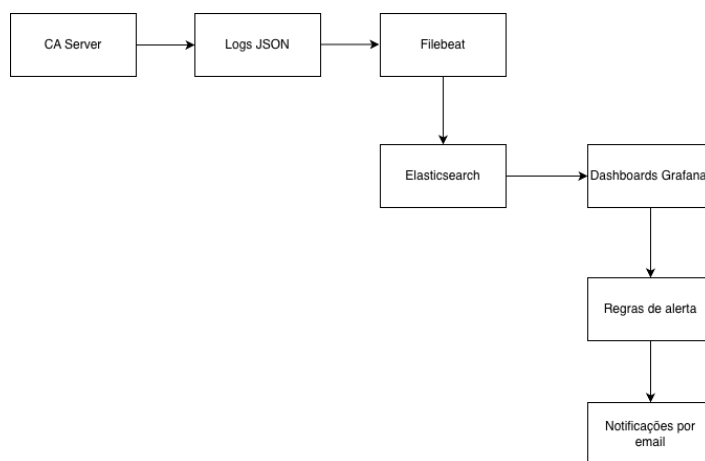


Figura 2: Arquitetura Monitorização

#### 7.2.1 Substituição do Certificado da CA

Neste cenário, o certificado do CA foi substituído diretamente na base de dados. O monitor de integridade recalcula periodicamente o hash SHA-256 dos certificados e

procede à sua comparação com o valor de referência armazenado. Após a alteração do certificado, ocorreu uma divergência entre os hashes, o que resultou num evento de segurança.

#### Indicadores ativados:

- event\_type = ca\_cert\_tampered
- severidade **CRITICAL**
- regra RULE-001

A alteração do certificado foi registada pelo sistema de monitorização. O log apresentado abaixo demonstra o momento em que foi detetada a divergência entre o hash esperado e o hash atual do certificado da CA, o que originou um evento do tipo `ca_cert_tampered` classificado como crítico.

```
[CRITICAL] ca_cert_tampered: {'cert_id': '43', 'cert_type': 'ca', 'expected_hash': 'b2155dfd689174dded37764836783a21c1e277afc3798289df695a624b87d878', 'actual_hash': '99c6dbad152d8dde59c317f1f610840a275409303a7d8d4b35ca9acf8a77ce9', 'triggered_rule': 'RULE-001: CERT_HASH_MISMATCH', 'mitre_technique': 'T1565.001 - Stored Data Manipulation', 'mitre_tactic': 'Tampering', 'recommended_action': 'Isolate CA Server and revoke affected certificates'}
```

Figura 3: Log da monitorização

No caso de o evento de segurança ter sido gerado pelo sistema de monitorização, o registo é guardado no ficheiro de logs em formato JSON. O Filebeat recolhe automaticamente estes registos e envia-os para o Elasticsearch, onde ficam armazenados e indexados. Posteriormente, o Grafana consulta o Elasticsearch para visualizar os eventos e avaliar as regras de alerta configuradas. Quando um evento corresponde às condições definidas numa regra de alerta, o Grafana altera o estado do alerta para *Firing* e desencadeia as notificações configuradas.

| State | Name                                          | Health | Summary                                                                      | Next evaluation       | Actions                                                                                                                                                                          |
|-------|-----------------------------------------------|--------|------------------------------------------------------------------------------|-----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|       |                                               |        | CRITICO: Cer<br>foi substituído                                              |                       |                                                                                                                                                                                  |
|       |                                               |        | MITRE ATT&C<br>Technique: T1<br>Stored Data<br>Manipulation<br>Tactic: Tampe | within<br>10<br>secon |                                                                                                                                                                                  |
| >     | CRITICO -<br>Certificado<br>CA<br>Substituído | ok     |                                                                              |                       |   More |
|       |                                               |        | Regra:<br>RULE-001:<br>CERT_HASH_J                                           |                       |                                                                                                                                                                                  |

Figura 4: Estado dos alertas

Após a ativação do alerta no Grafana, é enviada automaticamente uma notificação por email com os detalhes do incidente. Esta notificação inclui o resumo do alerta, a regra de deteção acionada e a técnica MITRE ATT&CK associada ao evento.

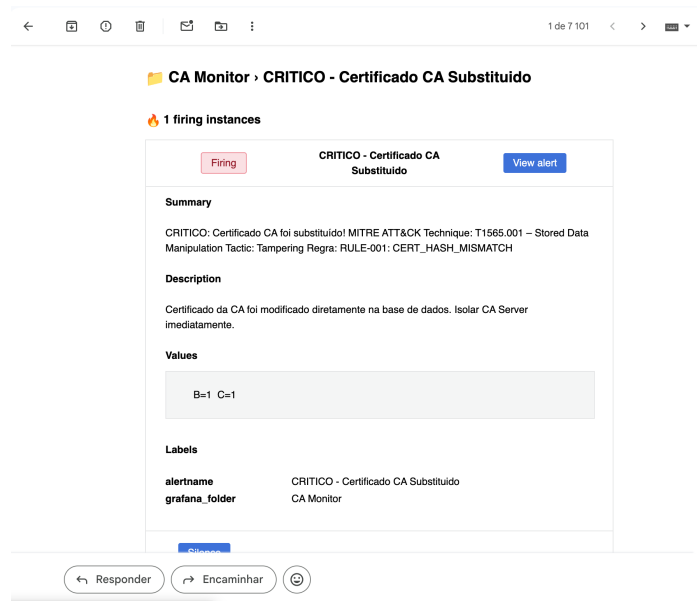


Figura 5: Email do alerta

### 7.2.2 Modificação de Certificado de Utilizador

Neste cenário, foi realizada uma alteração direta ao certificado de um utilizador armazenado na base de dados. O monitor de integridade recalcula periodicamente o hash dos certificados e procede à sua comparação com o valor de referência armazenado. Após a ocorrência da alteração, foi detetada uma divergência entre os hashes, o que resultou no desencadeamento de um evento de segurança do tipo `user_cert_tampered`.

**Indicadores ativados:**

- `event_type = user_cert_tampered`
- severidade **WARNING**
- regra **RULE-001**

O log apresentado abaixo mostra o evento gerado após a deteção da modificação do certificado de utilizador.

```
[WARNING] user_cert_tampered: {'cert_id': '28', 'username': 'ruicarvalho', 'expected_hash': '879b0bd7770bac225c0870b95cb73ec756929bdc7549b263b5b67d33d1f68cf9', 'actual_hash': '3c9d59bad88b8537118c2d0771da184c4e3e2d47759de4cc6dc1b6d37d3d1b8e', 'triggered_rule': 'RULE-001: CERT_HASH_MISMATCH', 'mitre_technique': 'T1565.001 - Stored Data Manipulation', 'mitre_tactic': 'Tampering', 'recommended_action': 'Revoke the user's certificate and reissue a new one'}
```

```
[MONITOR] 1 integrity violation(s) detected!
```

Figura 6: Log monitorização

Após o registo do evento no Elasticsearch, o Grafana avaliou a regra de alerta correspondente. Como a condição definida foi satisfeita, o alerta “WARNING – Certificado Utilizador Modificado” transitou para o estado *Firing*.

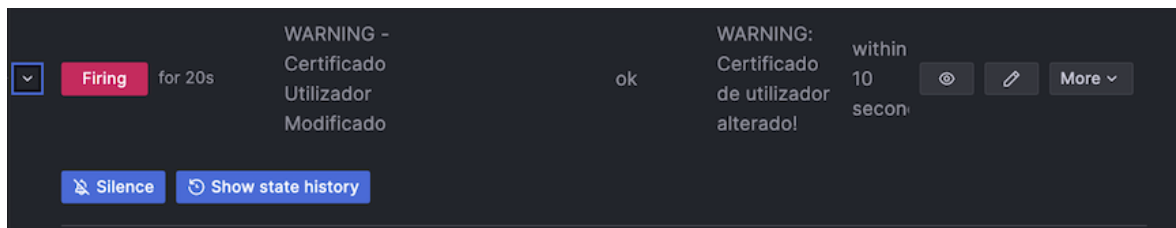


Figura 7: Alerta da modificação do certificado

No momento em que o alerta é ativado, o sistema envia automaticamente uma notificação por correio eletrónico com o resumo do incidente e a regra de deteção acionada.

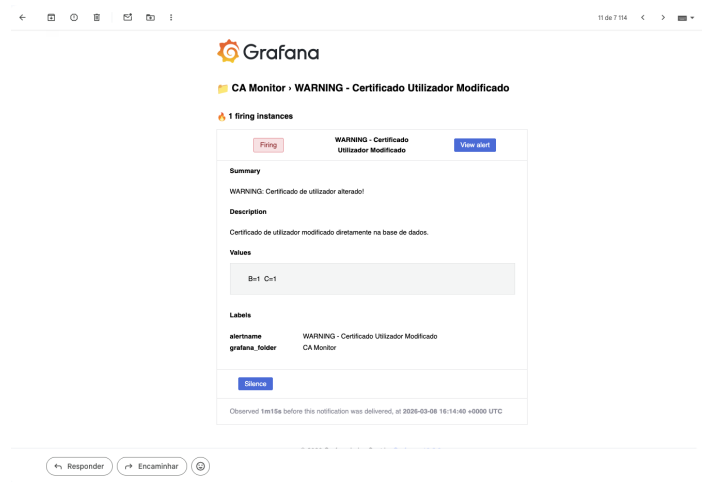


Figura 8: Email do alerta

### 7.2.3 Ligação Externa à Base de Dados e Tentativa de Exfiltração

Neste cenário foi simulada uma ligação externa à base de dados do servidor de certificados, seguida de um aumento significativo no número de consultas realizadas num curto intervalo de tempo. Este comportamento simula um atacante que obtém acesso à base de dados e tenta extrair um grande volume de certificados. O sistema de monitorização detetou primeiro a ligação externa à base de dados e posteriormente um comportamento anómalo caracterizado por um elevado número de consultas.

#### Indicadores ativados:

Durante a execução do cenário foram ativados dois indicadores distintos.

#### Ligação externa à base de dados

- event\_type = external\_db\_connection
- severidade **WARNING**
- regra **RULE-003**

#### Tentativa de exfiltração

- event\_type = exfiltration\_suspected
- severidade **CRITICAL**
- regra **RULE-004**

O log apresentado abaixo mostra os eventos que foram detetados após a ligação externa à base de dados e o comportamento anómalo de consultas.

```
{ "@timestamp": "2026-03-08T17:10:27.848364+00:00", "event_type": "external_db_connection", "severity": "WARNING", "log_source": "ca_server", "client_i"
{"@timestamp": "2026-03-08T17:10:28.852584+00:00", "event_type": "exfiltration_suspected", "severity": "CRITICAL", "log_source": "ca_server", "client_i
{"@timestamp": "2026-03-08T17:10:29.355697+00:00", "event_type": "exfiltration_suspected", "severity": "CRITICAL", "log_source": "ca_server", "client_i
{"@timestamp": "2026-03-08T17:10:29.860161+00:00", "event_type": "exfiltration_suspected", "severity": "CRITICAL", "log_source": "ca_server", "client_i
{"@timestamp": "2026-03-08T17:10:30.365984+00:00", "event_type": "exfiltration_suspected", "severity": "CRITICAL", "log_source": "ca_server", "client_i
```

Figura 9: Logs da ligação externa e exfiltração de certificados

Após o registo dos eventos no Elasticsearch, o Grafana avaliou as regras de alerta configuradas. Inicialmente, foi gerado um alerta de WARNING, a indicar uma ligação externa à base de dados. Posteriormente, quando o número de consultas excedeu o limiar definido, foi gerado um alerta CRITICAL associado a uma possível tentativa de exfiltração.

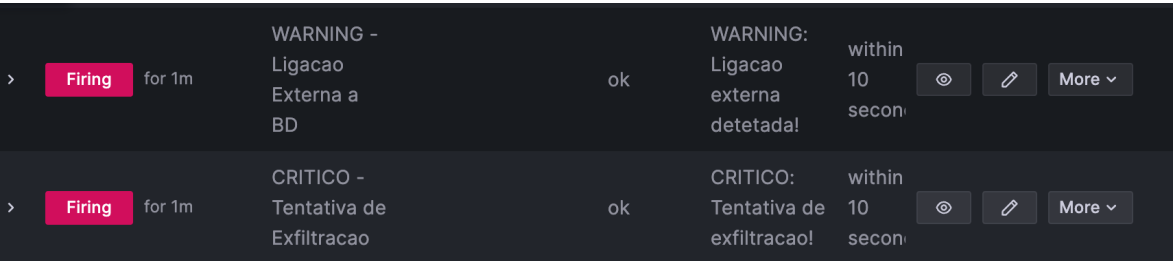


Figura 10: Alerta no grafana

No momento em que os alertas ativam o estado *Firing*, o sistema envia automaticamente notificações por e-mail, onde constam os detalhes do incidente detetado.

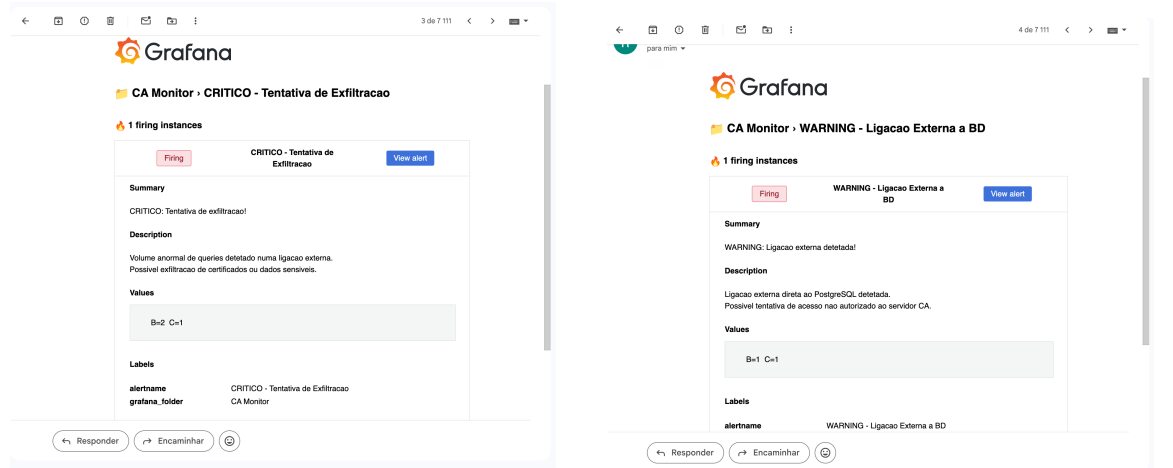


Figura 11: Emails dos alertas



## 7.3 Monitorização através do Dashboard

O dashboard do Grafana exibe métricas e eventos de segurança recolhidos pelo sistema de monitorização. A interface permite visualizar a evolução temporal dos eventos, o número de alertas críticos, ligações externas suspeitas e o estado das verificações de integridade dos certificados.



Figura 12: Alerta via Email

## 7.4 Integração do ciclo de inteligência

O ciclo de inteligência pode ser integrado no ciclo de vida do sistema através de um processo contínuo de recolha, análise e disseminação de informação sobre ameaças. Este não é um processo que deve estar isolado, mas sim integrado no ciclo de vida do sistema, contribuindo para a sua melhoria progressiva.

A recolha consiste na monitorização contínua do estado da integridade dos certificados, calculando e comparando os valores dos hashes. Juntamente com a consulta regular de fontes OSINT, que fornece um contexto atualizado sobre novas técnicas de ataque, é possível obter uma visão mais completa e panorâmica do risco.

A análise dos alertas e eventos gerados permite classificar a severidade dos incidentes, determinar uma resposta adequada e, até mesmo, identificar novas técnicas relevantes e atualizar os IoCs. Por fim, a disseminação propaga os resultados da análise através de dashboards Grafana para a visualização em tempo real do estado da integridade do sistema. Este processo contínuo contribui para a melhoria progressiva do sistema de monitorização, pois permite adaptar os mecanismos de deteção a novas ameaças e técnicas utilizadas por atacantes. Quando surgem novas CVEs relacionadas com

a infraestrutura PKI, quando são publicados novos TTPs relevantes, ou quando são detetadas lacunas nos cenários simulados, é essencial atualizar os IoCs e ajustar as regras de deteção. Assim, garante-se que a segurança do sistema evolui constantemente.

## 7.5 Conclusão

A estratégia de monitorização contínua implementada mostrou ser eficaz na deteção de alterações maliciosas e comportamentos anómalos no sistema de certificados do leilão. A integração de informação proveniente de OSINT e CTI permitiu identificar técnicas de ataque relevantes e transformá-las em indicadores de compromisso e regras de deteção. Os cenários de ataque simulados confirmaram a eficácia da arquitetura proposta na geração de alertas e na preservação de provas para análise. Desta forma, a monitorização contínua contribui para reforçar a postura de segurança do sistema e apoiar a sua evolução face a novas ameaças.